
정적 IoC 기반 시각화 대시보드 및 공격체인 분석 웹서비스

Cloud 기반 데이터 AI 파이프라인 프로젝트 중간 보고서

과목명 : Cloud•데이터•AI 파이프라인 구축

소속/학번 : /

이름 :

제출일 : 2026.07.05

목차

1. 프로젝트 개요	1
1-1. 프로젝트 배경 및 목적	1
2. 데이터 수집 설계	3
2-1. 데이터 출처 및 선택 사유	3
2-2. 수집 데이터 형식	4
2-3. 수집 방식 및 수집 주기	5
3. 데이터 처리 설계	6
3-1. Feature Extraction	6
3-2. 데이터 전처리	6
3-3. DB 스키마 설계	7
4. EDA 설계	8
4-1. EDA 목적	8
4-2. 분석 방법	8
4-3. ATT&CK 매핑	8
5. 웹서비스 설계	9
5-1. 시스템 아키텍처	9
5-2. 서비스 페이지 구성	10
6. 한계점	10
참고문헌	10

1. 프로젝트 개요

1-1. 프로젝트 배경 및 목적

오늘날 사이버 위협은 국가 배후 해커, 사이버 범죄 조직, 해커 등 다양한 위협 행위자에 의해 전개되고 있으며, 공격 방식 또한 자동화, 다단계 공격 체인, 취약점 악용, 정상 도구 악용 기법 등을 통해 점차 정교해지고 있다. 이에 따라 방어 측은 단순히 침해가 발생한 이후 대응하는 사후 대응(reactive) 중심의 보안 체계에서 벗어나, 공개 위협 정보와 보안 데이터를 활용하여 알려진 위협의 흐름을 파악하고 대응 우선순위를 판단하는 사전 대응(proactive) 관점의 보안 역량을 확보할 필요가 있다.

사이버 위협 인텔리전스(Cyber Threat Intelligence, CTI)에서 널리 활용되는 지표로는 침해지표(Indicator of Compromise, IoC)와 공격지표(Indicator of Attack, IoA)가 있다. IoC는 해시, 파일 시그니처, 도메인, IP 주소, 취약점 식별자와 같이 침해 또는 악성 행위와 관련된 기술적 흔적에 초점을 맞추는 지표이다. 반면 IoA는 공격이 진행되는 과정에서 나타나는 행위 패턴, 전술, 절차(TTP)를 바탕으로 공격 시도나 공격자의 의도를 조기에 파악하는 데 초점을 둔다

해당 프로젝트에서 활용하는 MalwareBazaar와 LOLDrivers는 모두 공개적으로 접근 가능한 위협 인텔리전스 데이터지만, 제공하는 데이터는 주로 악성코드 해시, 파일 메타데이터, YARA 매칭 결과, 취약점 드라이버 해시, 관련 CVE 등 정적 지표에 해당한다. 따라서 완전한 의미의 CTI 플랫폼이나 실시간 IoA 탐지 시스템을 구현하는 것이 아니라, 공개 IoC 데이터를 수집·정제·분석해 악성코드 탐지 동향과 공격 기법(TTP)의 연관성을 시각화하는 Technical CTI 기반 보안 데이터 대시보드를 구현하는 것을 목표로 한다.

또한 수집된 악성코드 패밀리명을 MITRE ATT&CK 프레임워크의 소프트웨어 목록과 매칭함으로써, 정적 지표만으로는 파악하기 어려운 공격 기법의 맥락을 제한적으로 해석하고자 한다. 이를 통해 단순한 해시 목록 조회를 넘어, 공개 위협 데이터를 기반으로 공격 기법과 방어 관점의 분석 흐름을 이해하는 데이터 파이프라인을 설계하고 구현한다.

프로젝트의 구조

- **메인(Main) 기능** — MalwareBazaar에서 수집한 악성코드 메타데이터를 기반으로 한 일반 위협 탐지 통계 대시보드
- **서브(Sub) 기능** — MalwareBazaar에서 수집한 악성코드 패밀리명(signature)을 MITRE ATT&CK Software 목록과 매칭하여, Tactic별·Technique별 통계를 제공하는 ATT&CK 매핑 탭

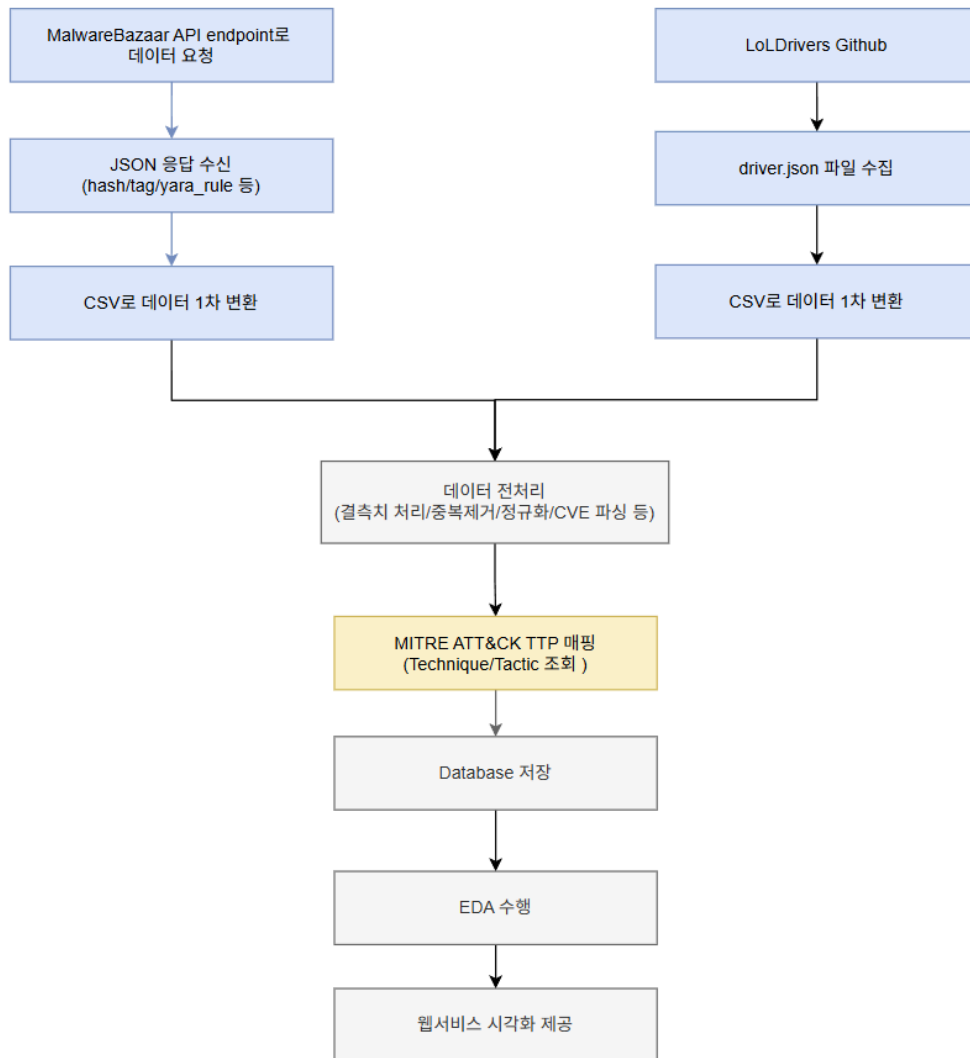


그림 1: 전체 데이터 파이프라인 Workflow 개요

2. 데이터 수집 설계

2-1. 데이터 출처 및 선택 사유

가. MalwareBazaar (abuse.ch)

MalwareBazaar는 스위스 비영리 보안 기관 abuse.ch가 운영하는 악성코드 공유 플랫폼으로, 무료 Community API를 공정 사용 원칙 하에 제공한다. 프로젝트에서는 `get_info` / `get_taginfo` / `recent_detections` 등의 엔드포인트를 통해 해시, 파일 시그니처, 태그, YARA 매칭 결과 등 메타데이터만을 수집한다. 이는 (1) 격리 환경 구축 없이도 안전하게 실습이 가능하고, (2) 이미 커뮤니티가 검증한 악성코드 패밀리 라벨을 확보할 수 있으며, (3) 파일 다운로드 API의 일일 제한(IP당 2,000건)과 무관하게 데이터를 수집할 수 있다는 점에서 선택하였다.

나. LOLDrivers

LOLDrivers는 공격자가 EDR/AV 무력화, 커널 권한 탈취 등에 실제로 악용해온 취약·악성 드라이버 목록을 해시, 서명 정보, 관련 CVE와 함께 공개하는 오픈소스 프로젝트이다. 본 프로젝트에서는 이를 MalwareBazaar와 별도로 독립된 하나의 IoC 데이터 수집원으로 취급하며, 별도의 해시 교차 검증 없이 드라이버명, 서명 정보, CVE, 카테고리(vulnerable/malicious) 등을 그대로 수집·저장한다.

다. YARA 정보 확보 방식에 대한 설계 결정

해당 프로젝트에서는 실제 악성행위를 수행하는 바이너리 파일을 확보하지 않으므로 `yara-python` 등을 이용한 자체 YARA 엔진 구동은 수행하지 않는다. 대신 MalwareBazaar API 응답에 이미 포함된 `yara_rules` 필드(커뮤니티가 사전 검증한 매칭 결과)를 활용한다. 이 설계는 다음 두 연구 결과에 근거한다.

- 해시 기반 매칭은 이미 알려진 악성코드만 탐지 가능한 반면, YARA 룰은 정보가 수집되지 않은 변종·신종 악성코드의 특성까지 식별할 수 있어(Al-Nemrat, 2021), 해시 매칭(LOLDrivers)만으로는 부족한 부분을 YARA 매칭 정보가 보완한다.
- 다만 공개 YARA 룰 생태계는 관리 주체가 분산되어 있고 최신성이 떨어지는 정적 데이터 공급망에 가까워지고 있어 실제 운용 시 상당한 오탐·누락이 발생할 수 있다(Dectot et al., 2026). 따라서 임의의 공개 룰을 직접 적용하기보다 MalwareBazaar가 바이너리 샘플로 교차 검증한 매칭 결과를 신뢰 가능한 소스로 활용한다.

라. MITRE ATT&CK 프레임워크 데이터

MITRE ATT&CK은 전 세계에 공개된 사이버 공격 사례를 바탕으로 구성된 전술(Tactic)·기법(Technique)·절차(Procedure) 지식 베이스로, STIX 2.1 형식의 데이터를 GitHub 저장소(mitre-attack/attack-stix-data)를 통해 무료로 제공한다. STIX 데이터에서 Technique는 `attack-pattern` 객체로, 악성코드/도구는 `malware/tool` 객체로 각각 존재한다. 이때, `relationship_type`이 `uses`인 별도의 `relationship` 객체가 `source_ref(malware/tool)`와 `target_ref(attack-pattern)`를 연결하는 방식으로 표현된다.

2-2. 수집 데이터 형식

두 데이터 소스 모두 REST API를 통해 JSON 형식으로 응답을 반환하며, 수집 스크립트는 이를 1차적으로 CSV로 변환해 저장한 뒤 데이터베이스에 전달한다. 각 소스에서 수집하는 주요 필드는 아래와 같다.

표 1. MalwareBazaar 수집 필드

CSV 컬럼	API 필드	용도
sha256_hash md5_hash	sha256_hash , md5_hash	샘플 식별 키
file_name file_size	file_name, file_size	샘플 상세정보, 크기 분포 EDA
file_type file_type_mime	file_type, file_type_mime	파일 유형 분포 EDA
signature	signature	악성코드 패밀리 라벨 (Top N 통계, ATT&CK SW 매칭 키)
tags	tags (list)	필터링, 태그 분포
first_seen / last_seen	first_seen, last_seen	시계열 추이 EDA
delivery_method	delivery_method	유입 경로 통계
origin_country	origin_country	지역 분포 (선택)
code_sign	code_sign	서명 여부 확인 (신뢰도 판단 보조 지표)
yara_rule_names	yara_rules[].rule_name (list)	YARA 매칭 근거

표 2. LOLDrivers 수집 필드

CSV 컬럼	API 필드	용도
driver_sha256 driver_md5 driver_sha1	KnownVulnerableSamples[]. SHA256/MD5/SHA1	드라이버 샘플 식별 키
filename	KnownVulnerableSamples[]. Filename	상세 표시
publisher / company	KnownVulnerableSamples[]. Publisher/Company	서명 주체 확인
category	Category	vulnerable / malicious 구분
tags	Tags	연관 그룹/악성코드군 태그
cve_id	Description / Resources 내 텍스트 파싱	참고용 메타데이터

표 3. MITRE ATT&CK 수집 필드

CSV 컬럼	STIX 필드	용도
software_name aliases	malware.name, tool.name, x_mitre_aliases	MalwareBazaar signature와의 이름 매칭 키
technique_id	attack- pattern.external_references[]. external_id	Technique 식별자 (예: T1055)
technique_name	attack-pattern.name	Technique 명칭
tactic	attack- pattern.kill_chain_phases[]. phase_name	해당 전술 (예: defense-evasion)

2-3. 수집 방식 및 수집 주기

본 프로젝트는 실시간 스트리밍이 아닌 배치(Batch) 방식으로 데이터를 수집한다. Cloud Scheduler(또는 로컬 cron)를 이용해 다음과 같은 주기로 수집기를 실행한다.

데이터 수집 목표는 최소 1,000건이다.

대상	엔드포인트	주기	비고
MalwareBazaar (일반 동향)	recent_detections	1회	시계열 EDA를 위한 날짜 분산 수집
MalwareBazaar (APT 그룹/패밀리)	get_taginfo(tag=...)	1회	태그당 최대 1,000건 제한 고려
LOLDrivers	drivers.json (GitHub)	1회	업데이트 빈도가 낮아 고빈도 수집 불필요
MITRE ATT&CK	enterprise- attack.json (GitHub)	1회	정적 참조 데이터, 재수집 불필요

3. 데이터 처리 설계

3-1. Feature Extraction

자체 YARA 엔진을 구동할 대상 파일은 존재하지 않으므로, Feature Extraction 단계는 다음과 같이 정의된다.

- MalwareBazaar API 응답의 `yara_rules` 필드(커뮤니티가 사전 스캔·검증한 매칭 결과)를 샘플별 Feature로 추출
- 샘플별 매칭된 `rule_name` 리스트, 매칭 룰 개수를 정형 데이터로 변환
- `signature` 필드(패밀리 라벨)와 `yara_rules`(세부 패턴 매칭 증거)를 별도 컬럼으로 분리하여, “무엇인지”와 “어떤 근거로 판단했는지”를 구분해 저장

3-2. 데이터 전처리

- **결측치 처리:** `signature` 값이 없는 샘플은 ‘unclassified’로 라벨링하여 통계에서 별도 그룹으로 관리한다.
- **리스트형 필드 평탄화:** `tags`, `yara_rule_names`는 세미콜론(;) 구분 문자열로 변환하거나, 정규화된 자식 테이블(`yara_matches`)로 분리한다.
- **해시 정규화:** 대소문자 통일(소문자 기준) 후 비교 및 매칭 수행한다.
- **날짜 포맷 통일:** `first_seen`, `last_seen` 등을 ISO 8601(YYYY-MM-DD HH:MM:SS) 형식으로 통일한다.
- **CVE 파싱:** LOLDrivers의 Description/Resources 텍스트에서 정규식(`CVE-\d{4}-\d+`)으로 CVE 번호를 추출하여 별도 컬럼으로 관리한다.
- **카테고리 구분 유지:** LOLDrivers의 `vulnerable`(정상 서명이나 취약함)과 `malicious`(이미 악성으로 확인됨)를 반드시 구분하여 표시한다.
- **ATT&CK 매핑 키 정규화:** `signature`(악성코드 패밀리명)를 ATT&CK STIX 데이터의 명칭·별칭 참조와 대조 가능한 형태(대소문자 통일, 별칭 처리)로 정규화하여 매칭률을 높인다.

3-3. DB 스키마 설계

PostgreSQL을 기준으로 아래와 같이 4개의 핵심 테이블을 설계한다. samples와 vulnerable_drivers는 각각 MalwareBazaar/LOLDivers 원천 데이터를 저장하고, yara_matches는 YARA 매칭 근거를 정규화한다. attack_ttp_mapping은 원천데이터를 MITRE ATT&CK Technique-Tactic과 연결하는 테이블이다.

```
CREATE TABLE samples (
    sha256_hash    VARCHAR(64) PRIMARY KEY,
    md5_hash       VARCHAR(32),
    sha1_hash      VARCHAR(40),
    file_name      TEXT,
    file_size      INTEGER,
    file_type      VARCHAR(20),
    signature      VARCHAR(100),
    tags           TEXT[],
    first_seen     TIMESTAMP,
    last_seen      TIMESTAMP,
    delivery_method VARCHAR(50),
    origin_country VARCHAR(10),
    code_sign      TEXT
);

CREATE TABLE yara_matches (
    id             SERIAL PRIMARY KEY,
    sha256_hash    VARCHAR(64) REFERENCES samples(sha256_hash),
    rule_name      VARCHAR(150)
);

CREATE TABLE vulnerable_drivers (
    hash_sha256    VARCHAR(64) PRIMARY KEY,
    driver_name    VARCHAR(150),
    category       VARCHAR(20),
    cve_id         VARCHAR(20),
    publisher      VARCHAR(150),
    source         VARCHAR(50) DEFAULT 'loldrivers'
);

CREATE TABLE attack_ttp_mapping (
    id             SERIAL PRIMARY KEY,
    signature       VARCHAR(100),
    software_name   VARCHAR(150),
    technique_id    VARCHAR(20),
    technique_name  VARCHAR(150),
    tactic          VARCHAR(50)
);
```

4. EDA 설계

MalwareBazaar와 LOLDrivers에서 수집한 IoC 데이터를 대상으로 악성코드 패밀리 분포, YARA 룰 매칭 빈도, first_seen 기준 시계열 추이, 파일 유형 및 크기 분포, ATT&CK TTP 매핑 결과 등을 탐색한다.

EDA는 Jupyter Notebook 환경에서 선행 수행한다. Notebook에서 데이터를 통한 분석 항목을 실험한 뒤, 해석 가능성과 시각화 가치가 높은 항목을 선별하여 Flask API 엔드포인트와 Vue.js 대시보드에 반영한다.

4-1. EDA 목적

- 탐지 동향: 어떤 YARA 룰/시그니처가 가장 빈번히 탐지되는가
- 시간적 패턴: 탐지 빈도가 특정 기간에 집중되는가, 꾸준한가
- TTP 연관성: 수집된 IoC(악성코드 패밀리 등)가 MITRE ATT&CK의 어떤 Technique·Tactic과 연결되는가, 매핑 비율은 어느 정도 인가

4-2. 분석 방법

분석 항목	방법	사용 컬럼
Top N 패밀리/YARA 룰	value_counts() 상위 N개 추출	signature, yara_rule_names
시계열 추이	resample('D'), 이동평균	first_seen
파일 유형 분포	value_counts() → 파이차트	file_type
파일 크기 vs 패밀리	groupby + describe(), 박스플롯	file_size, signature
TTP 매핑 비율	signature기준 attack_ttp_mapping 조회	signature
Technique/Tactic별 통계	매핑 결과 groupby + value_counts()	technique_id, tactic
카테고리 분포	vulnerable vs malicious 비중	category

4-3. ATT&CK 매핑

EDA 과정에서 확인된 signature은 MITRE ATT&CK STIX의 malware/tool 객체 명칭·별칭과 대조한 뒤, uses 관계를 통해 연결된 attack-pattern을 조회하여 공격 기법(TTP) 관점에서 해석한다. 프로젝트에서는 정적 데이터를 기반으로 하므로, 해당 매핑은 실제 공격 행위를 직접 관찰한 결과가 아니라 MITRE의 공식 문서화 데이터를 참고한 이름 기준의 정적 매핑이다.

매핑 결과 및 성공률은 수집된 패밀리명의 구성에 따라 달라질 수 있다. 따라서 EDA 초기 단계에서는 실제 수집 데이터를 대상으로 매핑 비율을 확인한다. 비율이 지나치게 낮을 경우 웹서비스 ATT&CK 매핑 탭에는 매핑된 샘플에 한해 정보가 제공된다는 점을 명시한다.

5. 웹서비스 설계

5-1. 시스템 아키텍처

본 프로젝트는 Flask(REST API) + PostgreSQL(DB) + Vue.js(프론트엔드)을 사용한 구조로 구현하며, 각 컴포넌트는 Oracle Cloud 환경에 배치한다. 그림 2는 전체 시스템 아키텍처를 나타낸다.

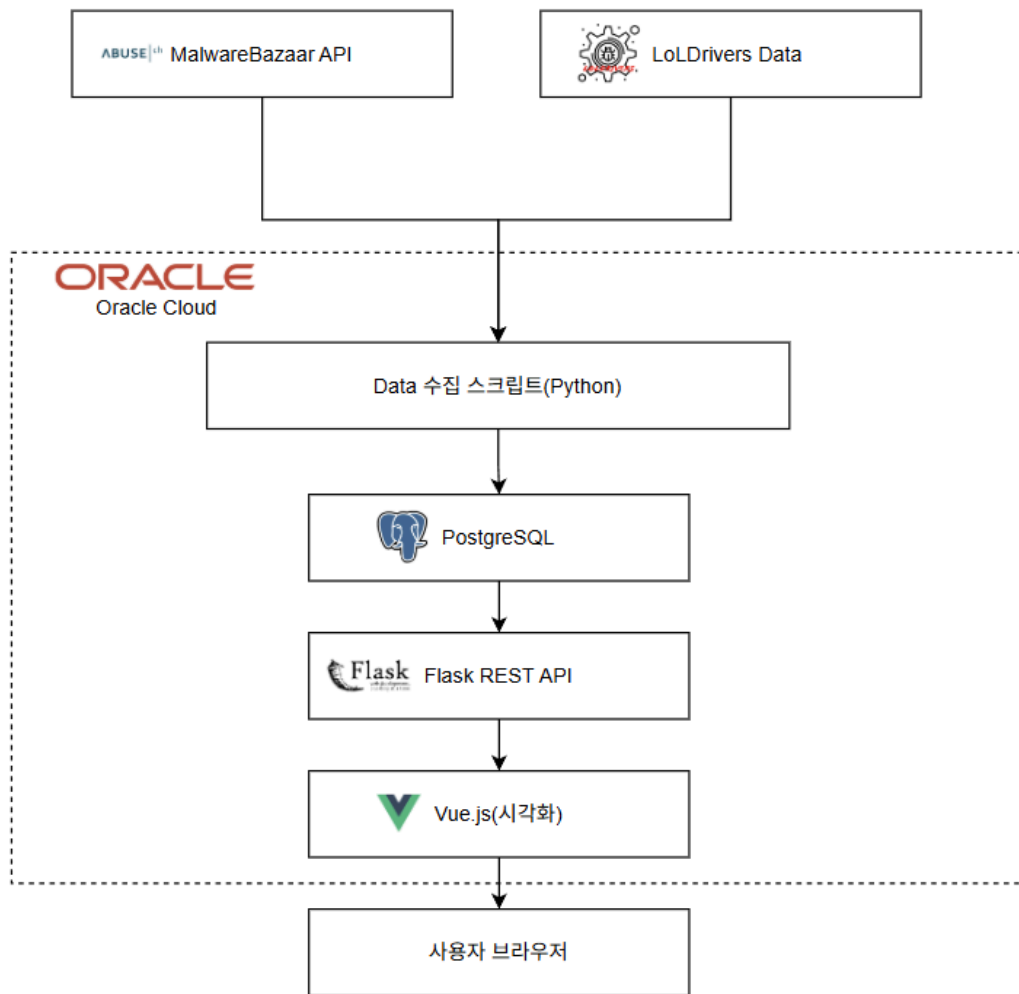


그림 2: 시스템 아키텍처 구조도

데이터는 python 스크립트로 MalwareBazaar API를 호출해 데이터를 수집해 CSV로 저장하고, LOLDrivers의 drivers.json을 가져와 수집한다. 또한 MITRE ATT&CK STIX 데이터를 함께 수집하여, MalwareBazaar의 악성코드 signature을 Technique·Tactic과 매핑할 수 있도록 준비한다. 수집한 결과는 가공하여 PostgreSQL에 저장한다. Flask REST API는 DB를 조회해 집계 결과를 JSON으로 제공하며, Vue.js로 시각화하여 사용자 브라우저에 렌더링한다. 개발 단계에서는 별도의 Jupyter 환경에서 EDA를 수행해, 어떤 분석 결과를 제공할지 결정한다.

5-2. 서비스 페이지 구성

표 4. 페이지별 구성 요소

페이지	주요 구성 요소	관련 차트/시각화
메인 대시보드	Top N 탐지 룰/패밀리, 시계열 추이, 파일 유형 분포	막대차트, 선그래프, 도넛차트
샘플 상세 조회	해시 검색 시 개별 샘플의 전체 메타데이터 표시	상세 테이블
ATT&CK 매핑 탭	IoC-Technique/Tactic 매핑 결과, 매핑룰	Top N Technique 차트, ATT&CK Matrix 스타일 히트맵
데이터 현황 (공통 Footer)	총 수집 건수, 수집 기간, 최종 업데이트 시각, 출처 표기	텍스트 요약

6. 한계점

- 본 프로젝트는 정적으로 공개된 메타데이터에 의존하므로, 실시간 위협 탐지나 행위 기반 분석은 범위에 포함되지 않는다.
- LOLDrivers는 업데이트 빈도가 낮아, 최신 사례를 즉각 반영하지 못할 수 있다.
- MalwareBazaar가 제공하는 YARA 매칭 결과에 의존하므로, 해당 결과의 정확도는 전적으로 MalwareBazaar 커뮤니티의 검증 수준에 좌우된다.
- signature와 ATT&CK STIX의 malware/tool 공식 명칭·별칭 간 표기 차이, 그리고 ATT&CK가 문서화하지 않은 커머티티 악성코드 패밀리의 존재로 인해 실제 연관성이 있음에도 매칭되지 않는 사례가 발생할 수 있다. 사전 검증 결과 유명 패밀리 위주 표본에서는 매칭률이 60% 이상으로 나타났으나, 무작위 수집 데이터에서는 이보다 낮을 수 있다.

참고문헌

- Lehto, M., & Koskimäki, T. (2025). Cyber Threat Intelligence and IoCs and IoAs Search on the Dark Web. In C. Lipps & B. Han (Eds.), Proceedings of the 24th European Conference on Cyber Warfare and Security (pp. 348-356). Academic Conferences International.
- Al-Nemrat, A. (2021). Assessing the Effectiveness of YARA Rules for Signature-Based Malware Detection and Classification. arXiv:2111.13910.
- Dectot-Le Monnier de Gouville, E., Hamdaqa, M., & Chouchen, M. (2026). Mining the YARA Ecosystem: From Ad-Hoc Sharing to Data-Driven Threat Intelligence. arXiv:2603.14191.
- abuse.ch. (n.d.). MalwareBazaar Community API. Retrieved from <https://bazaar.abuse.ch/api/>
- LOLDivers Project. (n.d.). Living Off The Land Drivers. Retrieved from <https://www.loldivers.io/>
- MITRE ATT&CK. (n.d.). ATT&CK STIX Data. Retrieved from <https://github.com/mitre-attack/attack-stix-data>